

מודול 12 — Pivoting ותנועה רוחבית — תרגול

חומר לימוד

1 יחידות

תוכן העניינים

1. 🧠 תרגול — מודול 12: Pivoting ותנועה רוחבית

תרגול — מודול 12: Pivoting ותנועה רוחבית

חלק א' — שאלות תרגול (עם תשובות). חלק ב' — תרגיש מהחיים האמיתיים.

חלק א' — שאלות תרגול

Q1. מהו Pivoting, ולמה הוא נחוץ ברשתות אמיתיות?

Q2. מהו Dual-Homed Host, ואיך תזהה אותו אחרי פריצה?

Q3. מה ההבדל בין `ssh -L`, `ssh -R` ו-`-D`?

Q4. מהו proxychains, ולמה חובה `-sT` ו-`-Pn` ב-nmap דרכו?

Q5. איך מפייבטים עם Metasploit? מה עושה `autoroute`?

Q6. מתי תשתמש ב-Chisel במקום SSH?

Q7. מהו Double Pivot?

Q8. איזו הגנה ארגונית מקשה על Pivoting?

תשובות

- שימוש במכונה שנפרצה כגשר לרשת פנימית לא-נגישה; היעדים הרגישים כמעט תמיד ברשת פנימית.
- מכונה עם שני ממשקי רשת (שתי רשתות); מזהים עם `ip a`, `ip route`, `arp -a`.
- `-L` מביא שירות פנימי אליך; `-R` פותח פורט על ה-Pivot שמנתב אליך; `-D` יוצר SOCKS proxy דינמי מלא.
- כלי שמריץ תוכנות דרך פרוקסי; `-sT` כי SYN לא עובר ב-SOCKS, `-Pn` כי ICMP לא עובר (אחרת המכונה תדולג).
- `run autoroute -s <net>` מוסיף route דרך ה-session; מודולי Metasploit "רואים" את הרשת הפנימית; `socks_proxy` לכלים חיצוניים.
- כשאין SSH על ה-Chisel; Pivot; בינארי יחיד, חוצה-פלטפורמות, ועובד מעל HTTP (עוקף Firewalls).
- שרשור מנהרות: פורצים מכונה פנימית ומפייבטים ממנה לרשת עמוקה יותר.

חלק ב' — תרחיש מהחיים האמיתי

“מה-DMZ אל שרת הכספים” 

פרצת שרת web ב-DMZ של חברה (192.168.1.50). ב-Looting (מודול 11) מצאת שהמכונה מחוברת גם לרשת 10.10.10.0/24 — שם יושב שרת מסד הנתונים הפיננסי (10.10.10.30), שלא נגיש לך ישירות.

1. גילוי: `ip a → eth1: 10.10.10.5/24` ← רשת פנימית
2. מנהרה: `ssh -D 9050 www-data@192.168.1.50`
`/etc/proxychains4.conf → socks5 127.0.0.1 9050`
3. סריקה: `proxychains nmap -sT -Pn -p 1433,3306,445 10.10.10.30`
→ פתוח 3306/mysql
4. תקיפה: `proxychains mysql -h 10.10.10.30 -u root -p`
(Looting-שאספת ב config.php סיסמה מקובץ)
5. גישה למסד הנתונים הפיננסי.

המשימה: 1. איזה מידע ממודול 11 (Looting) **אפשר** את הצעד האחרון? הסבר את החיבור. 2. כתוב את שורת ה-proxychains המדויקת לסריקת פורט 3306 על היעד. 3. אילו **שתי** המלצות תיקון היו מונעות את כל השרשרת?

פתרון מנחה 💡

1. **סיסמת ה-DB מקובץ הקונפיג** (config.php) שנאספה ב-Looting — בלעדיה לא היינו מתחברים למסד. זו הדגמה מושלמת לאיך Post-Exploitation מזין Pivoting.
2. `proxychains nmap -sT -Pn -p 3306 10.10.10.30`
3. (א) **Network Segmentation** — חסימת תעבורה משרת ה-DMZ לרשת הפנימית; (ב) **אי-אחסון סיסמאות בטקסט גלוי** בקובצי קונפיג + least-privilege למשתמש ה-DB.

🎯 שרשרת “DMZ → רשת פנימית → נתונים רגישים” היא בדיוק מה שתוקפים אמיתיים עושים. Segmentation טוב = הגבול שעוצר אותם.

← חזרה למודול · תרגילים מעשיים